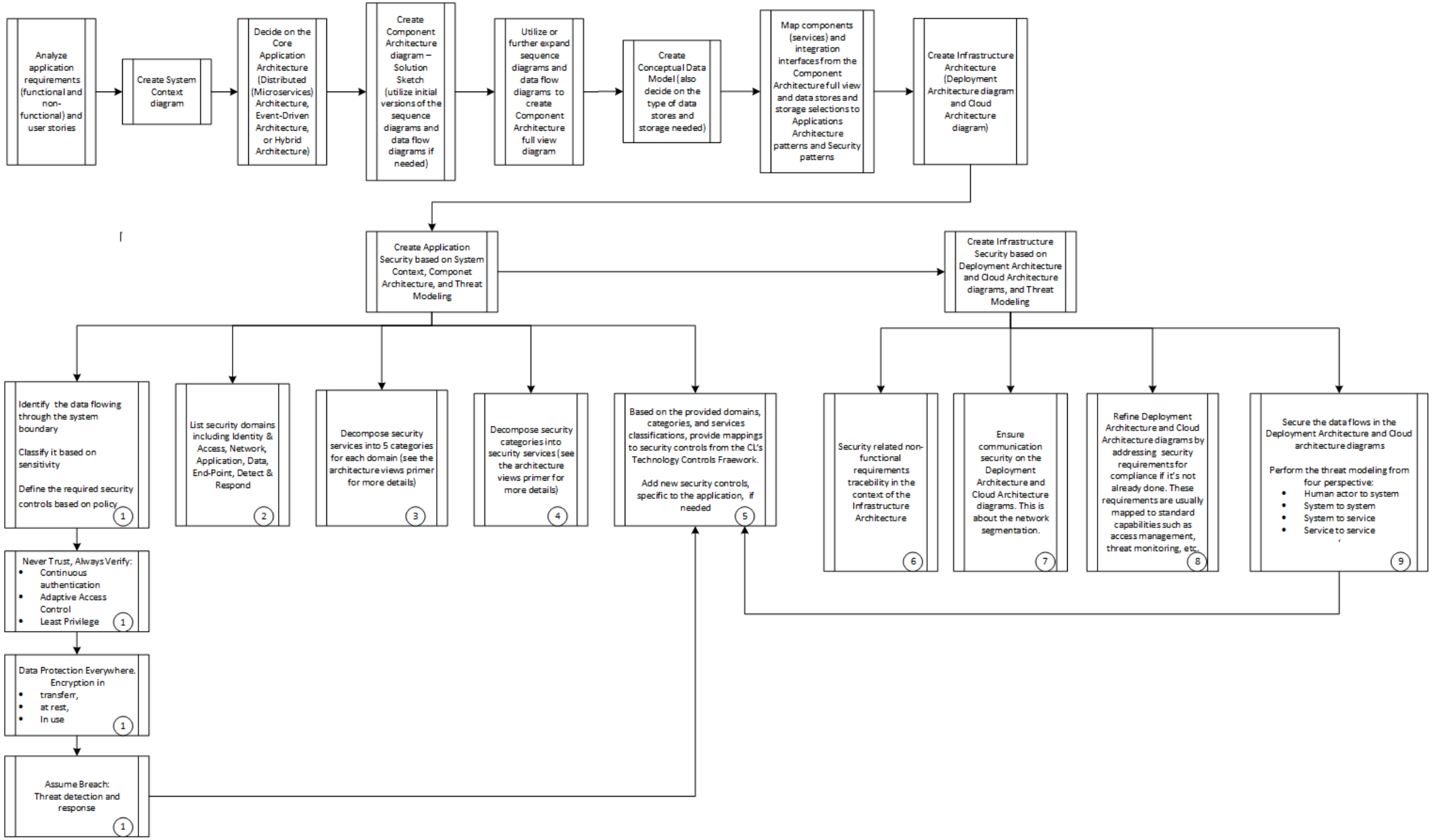
Architecture Views

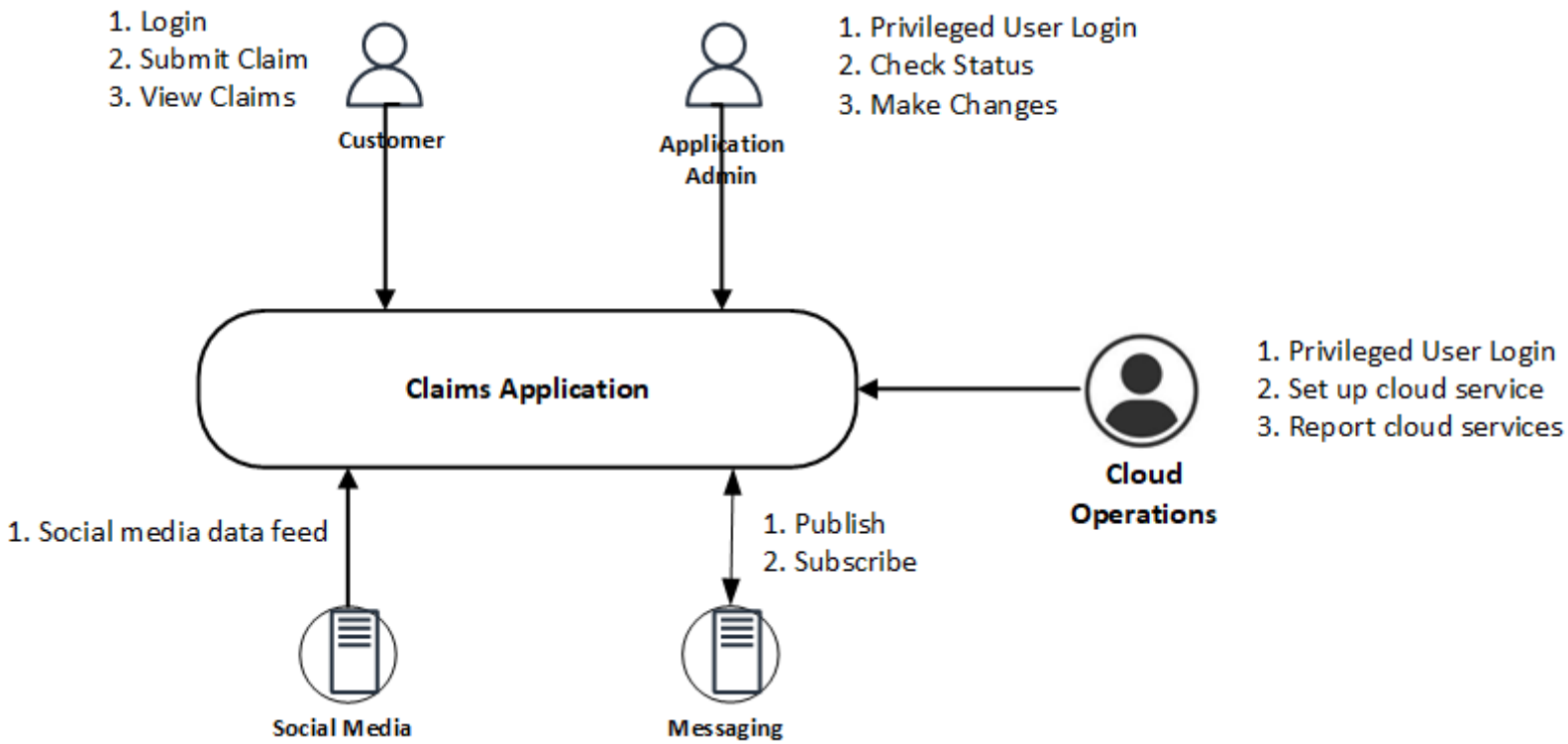
Architecture Views development Flow



Business Capability Model

TBD

System Context

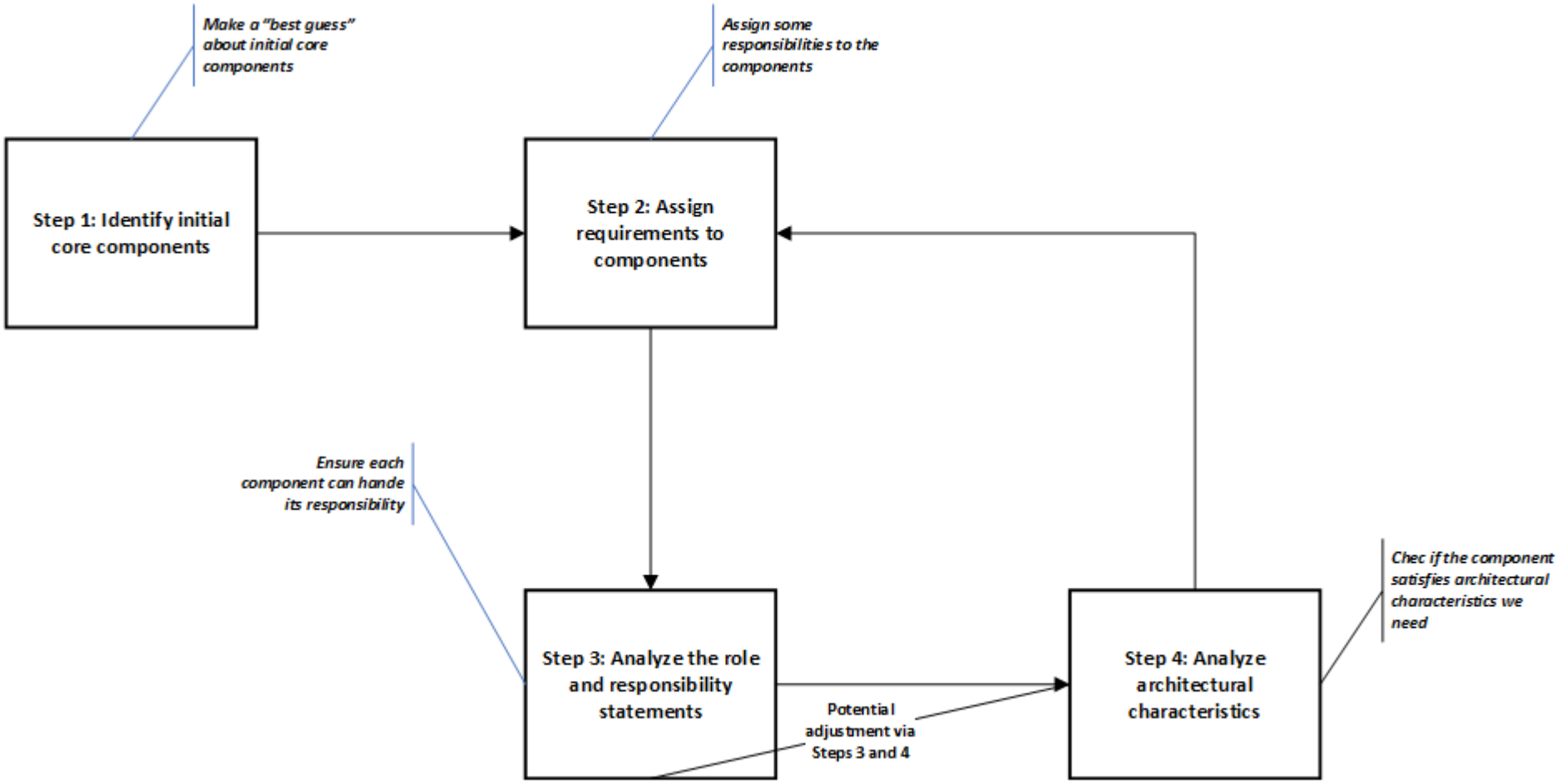


Core Application Architecture - AD

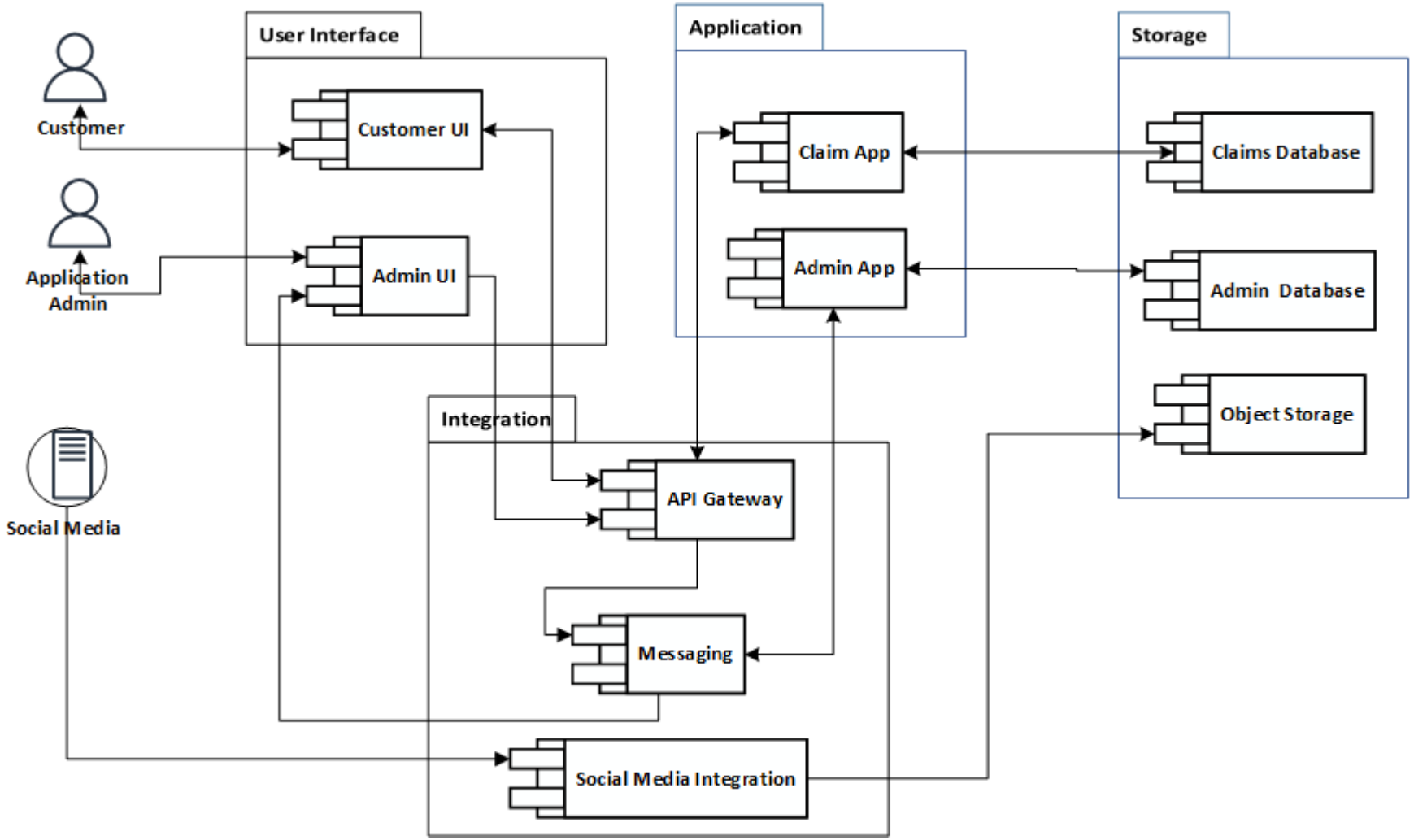
ID	Decision	Rationale	Implication
AD-01	Event-Driven Architecture		
AD-02	Database Architecture – Database-per-Service, Strict Consistency		

- Current options for core architecture are:
  - Distributed (Microservices) Architecture
  - Event-Driven Architecture
  - Hybrid Architecture

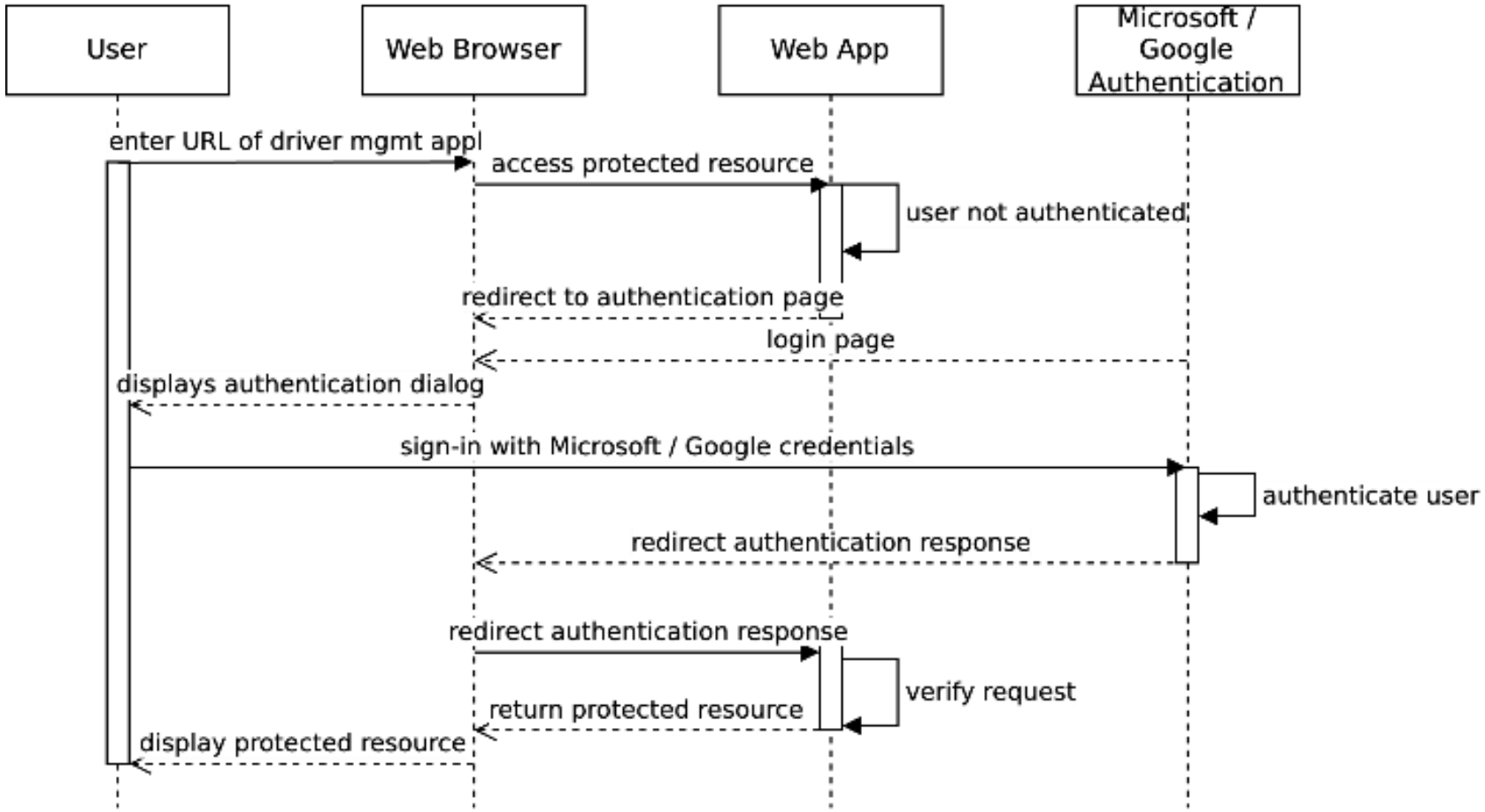
Component Architecture – dev steps



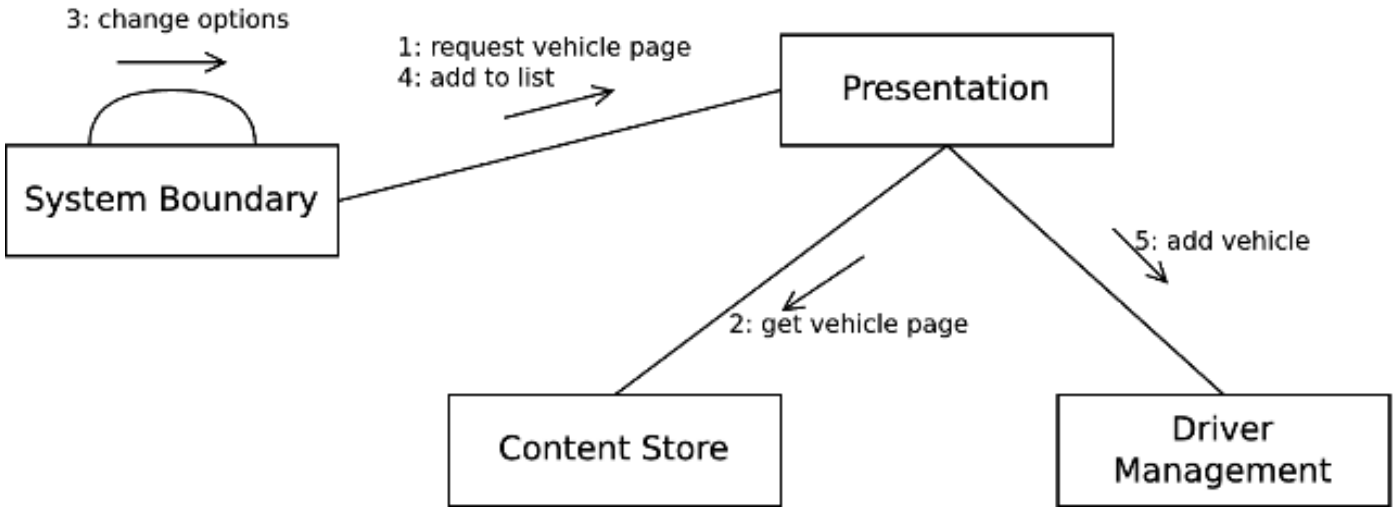
Component Architecture



Sequence Diagrams



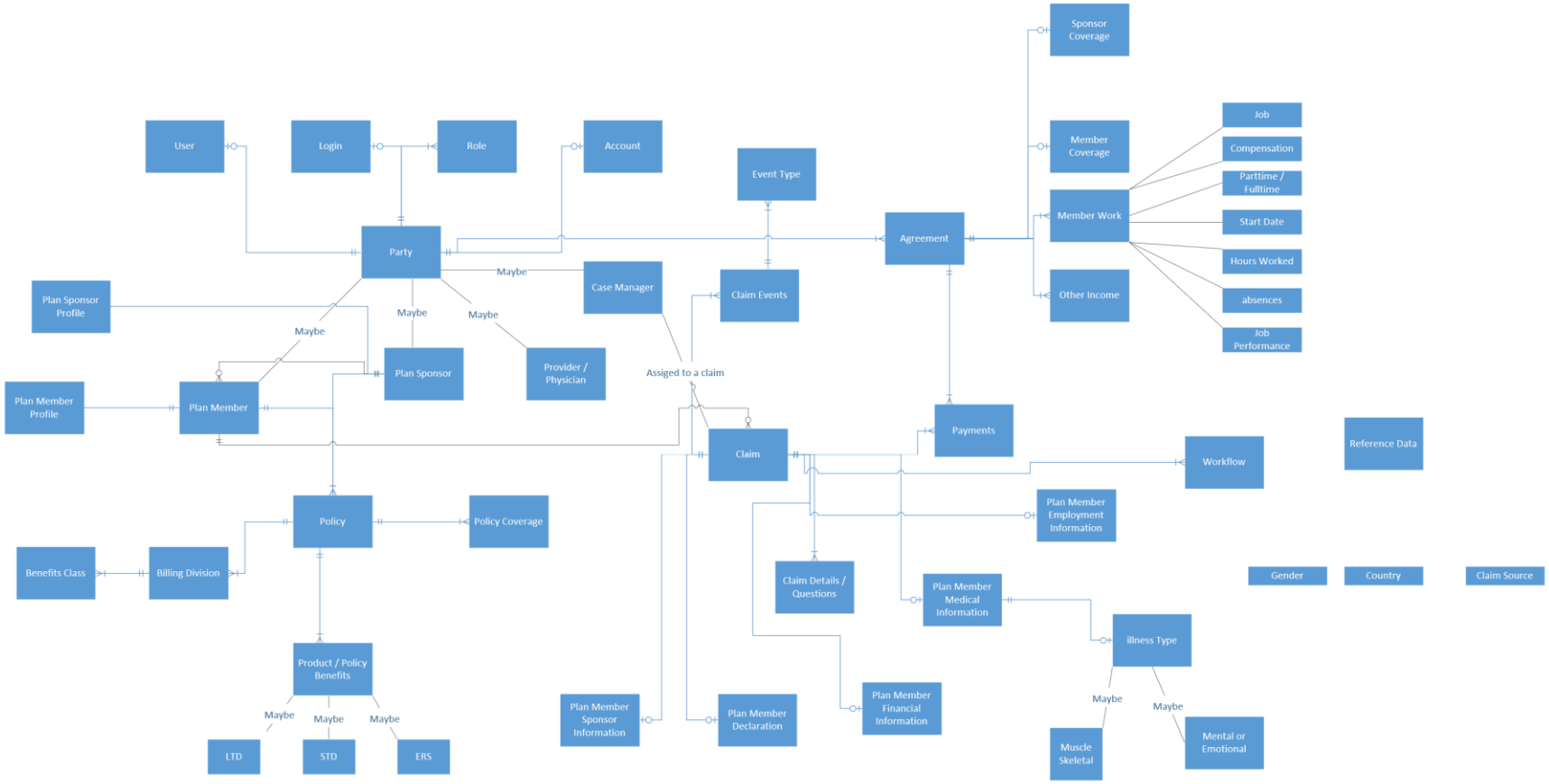
Data Flow Diagrams



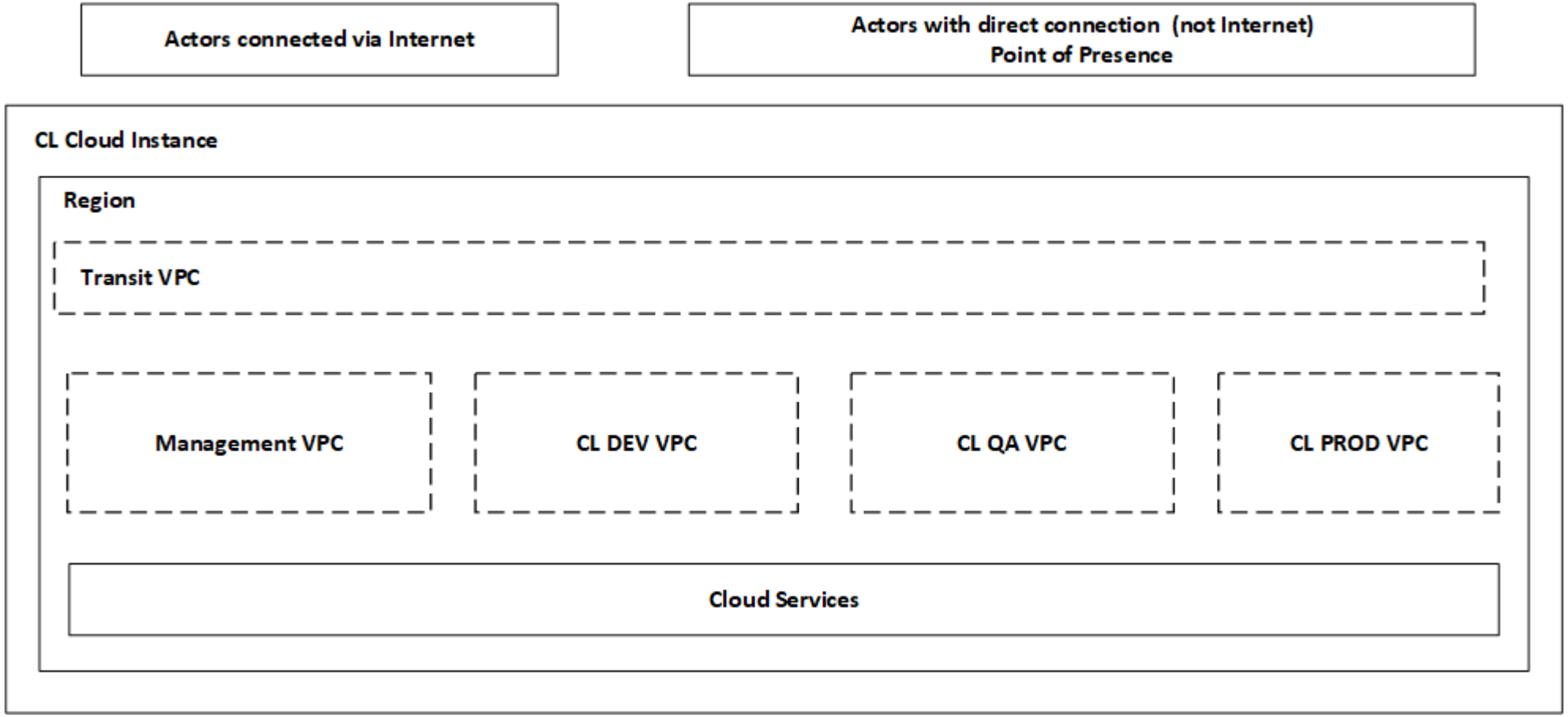
Components to Architecture Patterns Mapping

Type	Purpose	Pattern	Technology Service	Component ID
Application Components	Claim app	The Twelve-Factor App		AC-01
		Microservice	Spring Cloud AWS	
		API Routing	Amazon API Gateway	
		Service Registry - 3rd Party Registration		
		Service Discovery – Server-side Discovery		
		Service Mesh		
		Circuit Breaker		
		Retry with Backoff		
		Throttling		
	Admin App	The Twelve-Factor App		AC-02
		Microservice		
User Interface	Customer UI			UI-01
	Admin UI			UI-02
Databases & Storage	Claims Database	NoSQL	AWS MongoDB Atlas	DBS-01
	Admin Database	Relational	AWS RDS PostgreSQL	DBC-02
	Object Storage	Object Storage	AWS S3	DBS-03
Integrations	Messaging	Publish-Subscribe	AWS SNS	INT-01
	Social Media Integration			INT-02
	API Gateway	API Gateway	Apigee	INT-03

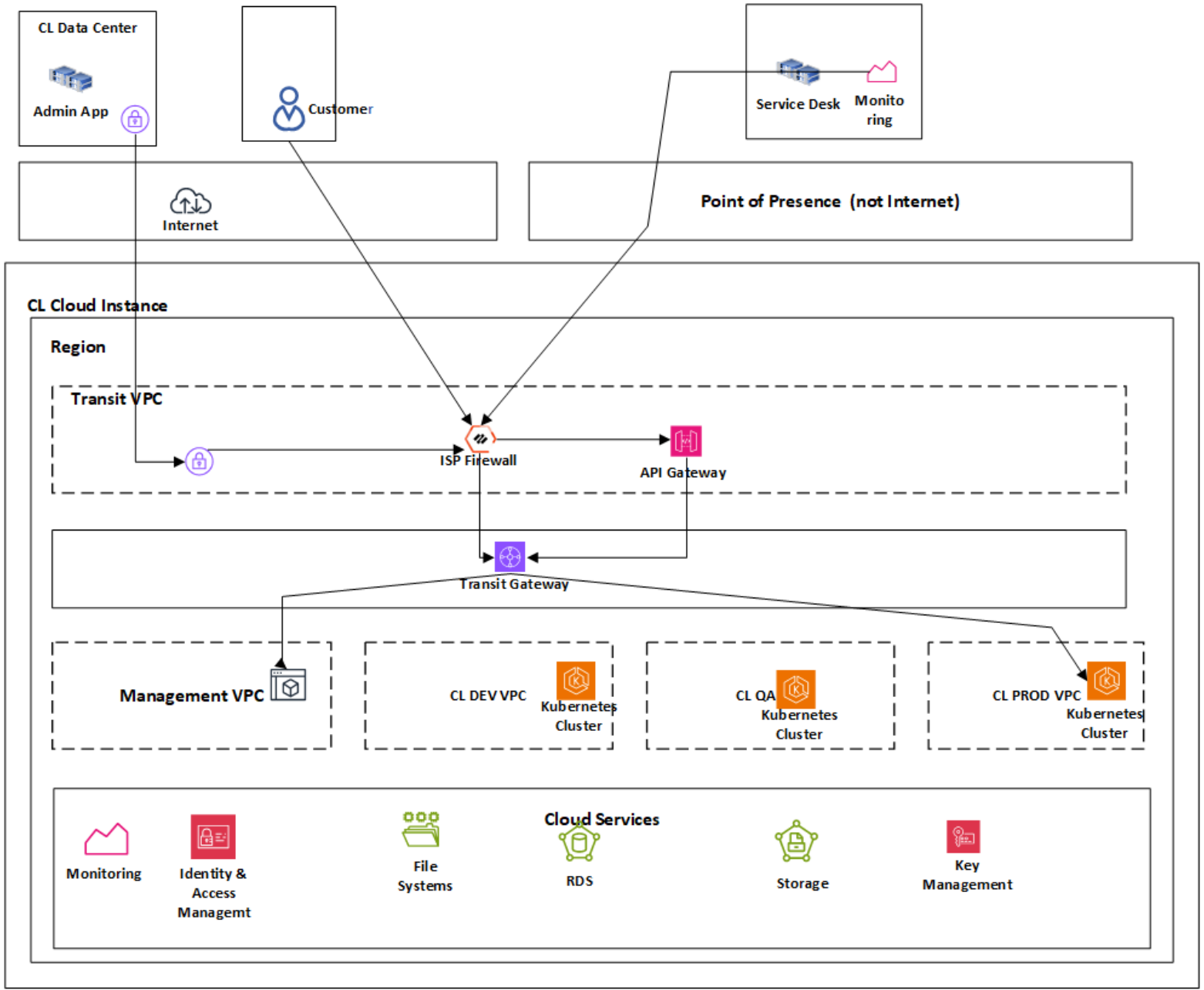
Conceptual Data Model



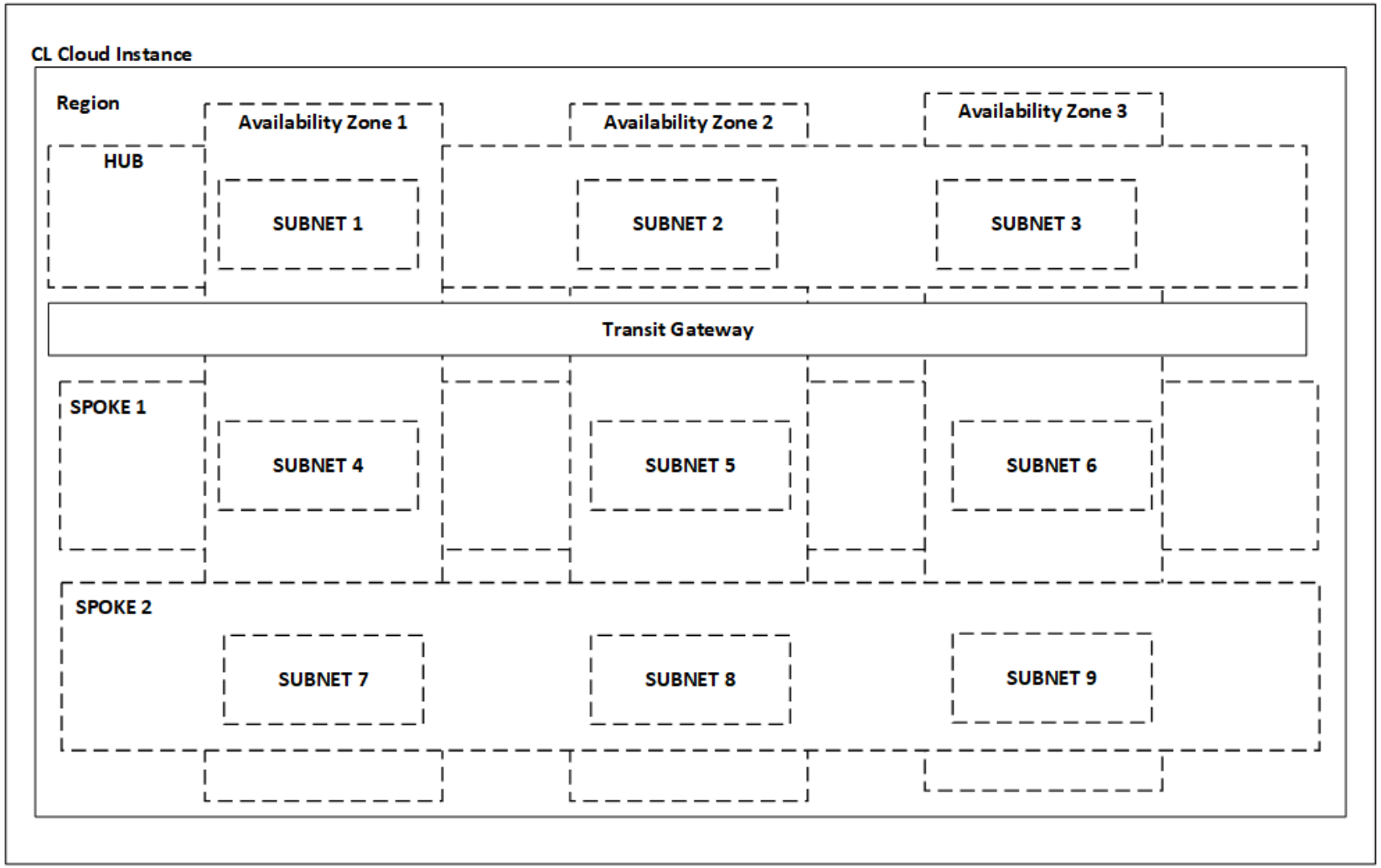
Deployment Architecture – Network Segments (Zones)



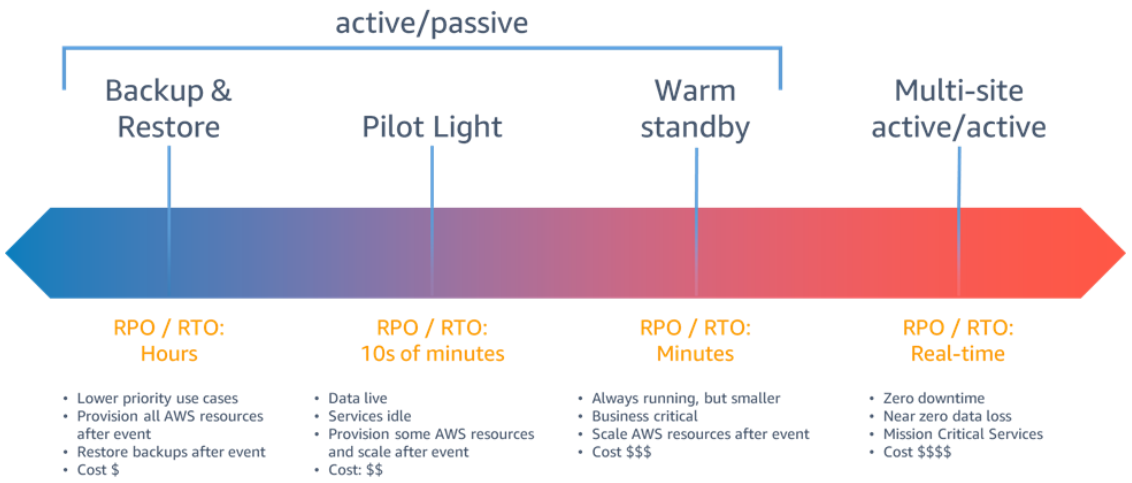
Deployment Architecture – full diagram

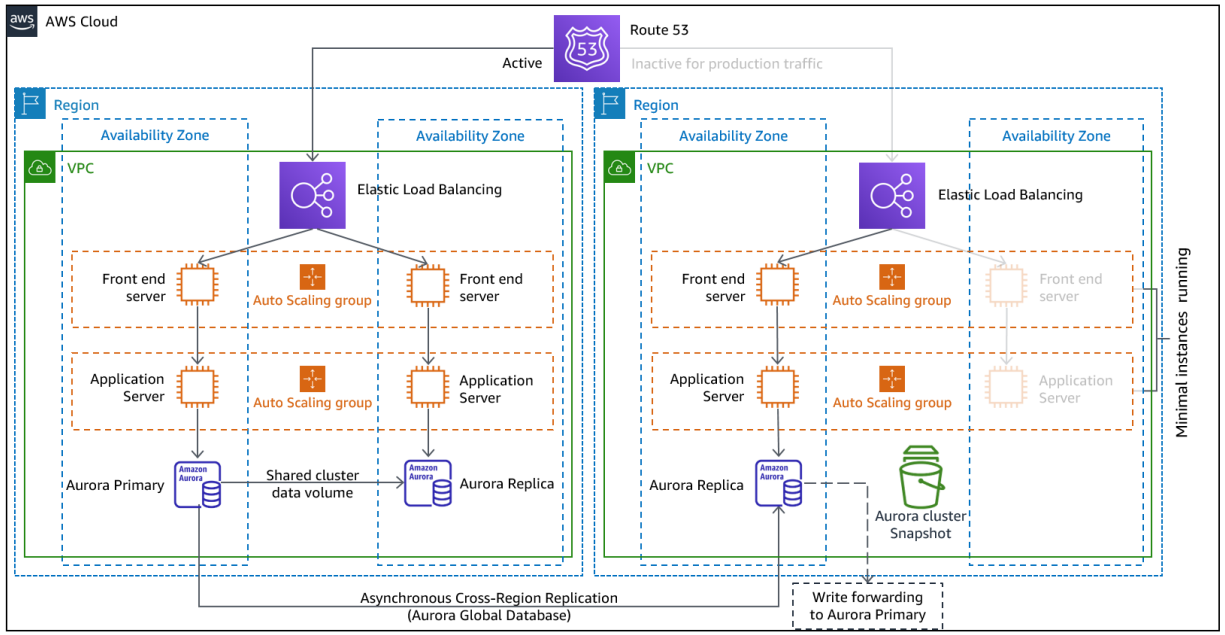


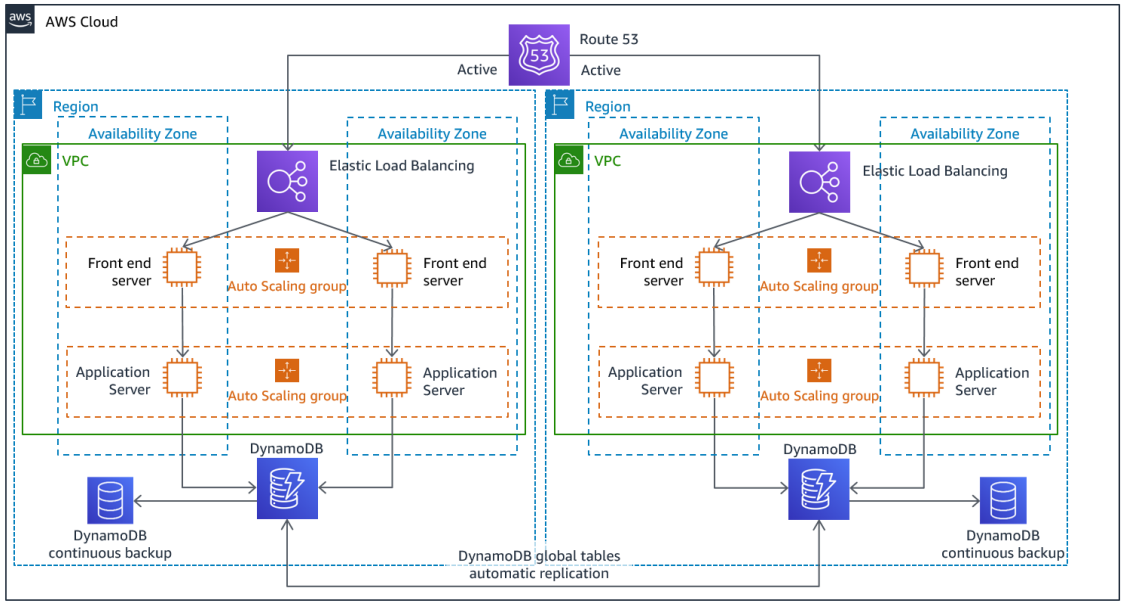
Cloud Architecture – high availability and DR



Cloud Architecture – high availability and DR (cont.)







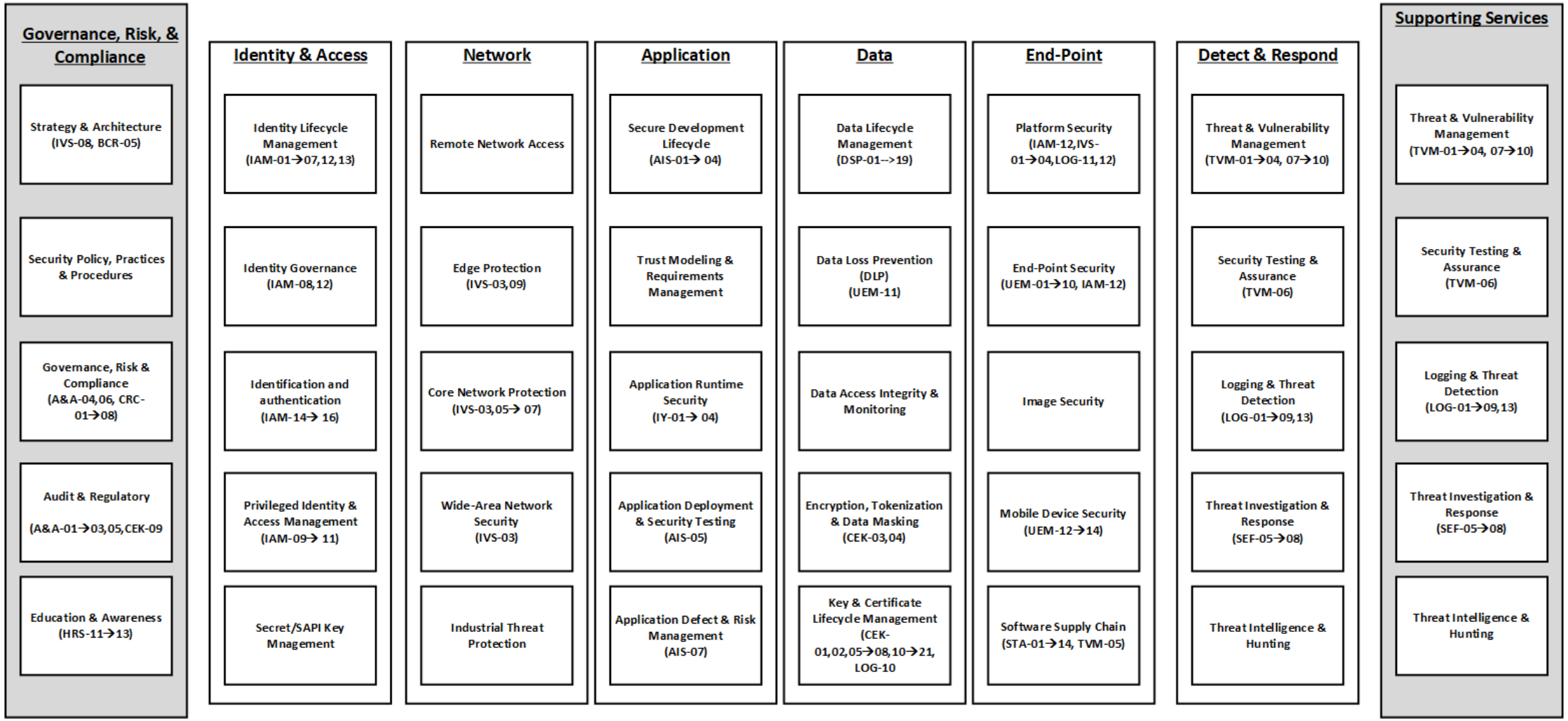
Security

Security - Plan

- Zero Trust Principles
  - Data Centric Security
    - Identify data flowing through system boundaries
    - Classify data based on sensitivity
    - Define the required security controls based on policy
  - Never Trust, Always Verify
    - Continuous authentication
    - Adaptive access control
    - Least privilege
  - Data Protection Everywhere
    - Encrypt dat ain transit, at rest, in use
  - Assume Breach
    - Threat detection and response

Application Security – domains, categories, services

Cloud Security Alliance Cloud Control



Application Security – detailed security services view - example

Identity & Access	Network
Identity Lifecycle Management • Joiners, Movers, Leavers (JML) • Create, Modify and Delete ID • Application Access Request • Emergency Leaver Process etc.	**Remote Access Security** • User Remote Access • Site-to-Site VPN • Direct Connection etc.
Identity Governance • Employment Revalidation • Role/Attribute Revalidation • Service Access Revalidation etc.	Edge Protection • Firewall • Web Application Firewall • Malware Scanning • Intrusion Detection & Prevention etc.

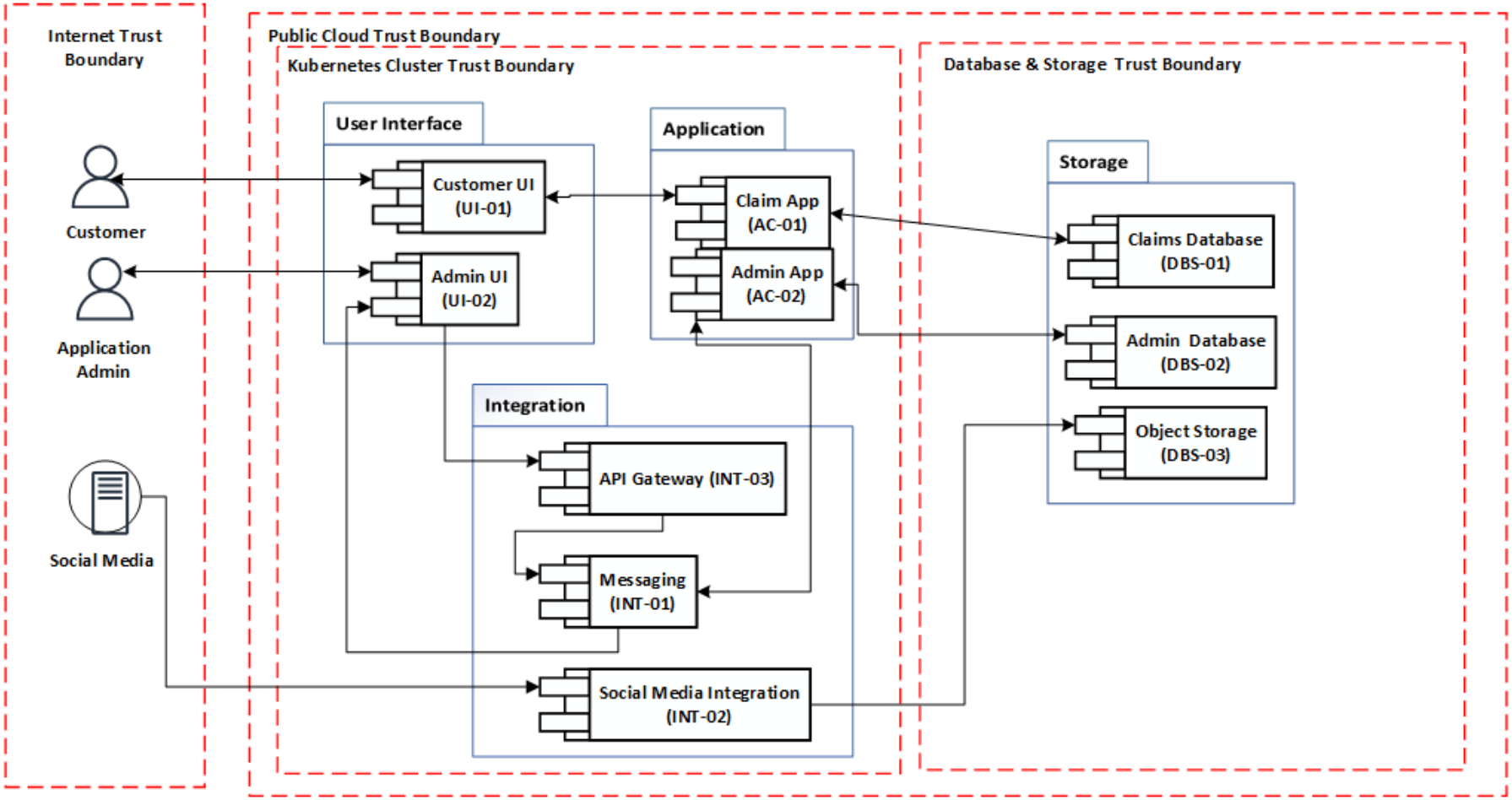
Application Security – teams' responsibilities examples

Security Operations	**Identity & Access** • Identity Lifecycle Management • Identity Governance • Privilege Access Management	**Network** • Edge Firewall • Network Intrusion Prevention	**Application**	**Data** • Hardware Security Module (HSM) • Multi-cloud key management	**End-Point** • XDR • Malware Detection	**Detect & Respond** • SIEM • SOAR
Infrastructure Operations	**Identity & Access**	**Network** • VPC Network Administration	**Application** • Application Encryption	**Data**	**End-Point** • Secure Build • Compliance Checking	**Detect & Respond**
Cloud Platform Public Services	**Identity & Access** • Cloud User Identities • RBAC • Secrets Manager	**Network** • Access Control List • Virtual End Point	**Application** • Application Encryption Toolkit	**Data** • Key Manager • Block Storage Encryption • Kafka Encryption	**End-Point** • Virtualisation Security • Server Encryption	**Detect & Respond** • Activity Logging
Cloud Platform Private Services	**Identity & Access** • Privilege Access Manager • Privilege Access Gateway	**Network** • Trusted Time Source	**Application**	**Data** • Key Manager and HSM	**End-Point** • End-point compliance	**Detect & Respond** • SIEM

Application Security – Thread Modeling

- There are six steps in the development of the threat model:
  - Identify boundaries
  - Identify Assets
  - Identify Threat Actors
  - Identify Threats
  - Identify Controls
  - Prioritization of Controls

Application Security – Component Architecture – trust boundaries



Application Security – Component Architecture – assets, threat actors, threats, controls

- Identify and Classify Assets. For example:
  - Crown jewels

    Data that represents the most valuable information assets for the organization, and if disclosed, modified, or made unavailable, it could cause the business to fail.
  - Personal Information (PI)

    Personal data that if it is disclosed, it shouldn't cause irrevocable harm to the person. For example, name and address.
  - Sensitive Personal Information (SPI)

    Personal data that if it is disclosed, it could cause irrevocable harm to the person. For example, physical or mental health, political opinions, racial or ethnic origin, religious beliefs, etc..
  - Financial Information

    Personal financial data, including bank records, tax records, and accounting records.
- Identify Threat Actors. For example:
  - External Threat Actors

    External threat actors are external to the organization. There are two types of them:
    - External authorized malicious actors – individuals with legitimate access and malicious intent.
    - External unauthorized malicious actor – individuals without legitimate access and malicious intent. This can also be further broken down into nation-state-sponsored, activists, criminal organizations, etc.
  - Internal Threat Actors

    Internal threat actors are internal to the organization. This can be an employee, a contractor, etc. someone who has legitimate insights about the organization. There are three types of them:
    - Internal unauthorized malicious actor – individuals without legitimate access and with malicious intent
    - Internal authorized, "honest but curious" actors – individuals with legitimate access to the data, just not all the data.
    - Inadvertent - These individuals inadvertently compromise security through careless actions or a lack of awareness.

Application Security – Component Architecture – assets, threat actors, threats, controls (cont.)

- Identify Threats
  - In case of manual threat modeling, we can start with high-level threats informed by OWASP Top 10.
  - For a more structured approach to developing threats and mitigation techniques, methods like STRIDE or attack trees, are recommended. More details about these techniques are available in Threat Modeling - Designing for Security.
  - The MITRE ATT&CK framework provides a framework for a more low-level threat analysis as well as for the identification of mitigation approaches. We should leverage threat modeling tools that feed information from MITRE, NIST, and CERT databases and allow a more comprehensive way of documenting the different elements of a threat model.
  - Privacy related issues are not specifically addressed in the previously mentioned techniques. The LINDDUN Privacy Threat Modelling Framework addresses the privacy related issues.

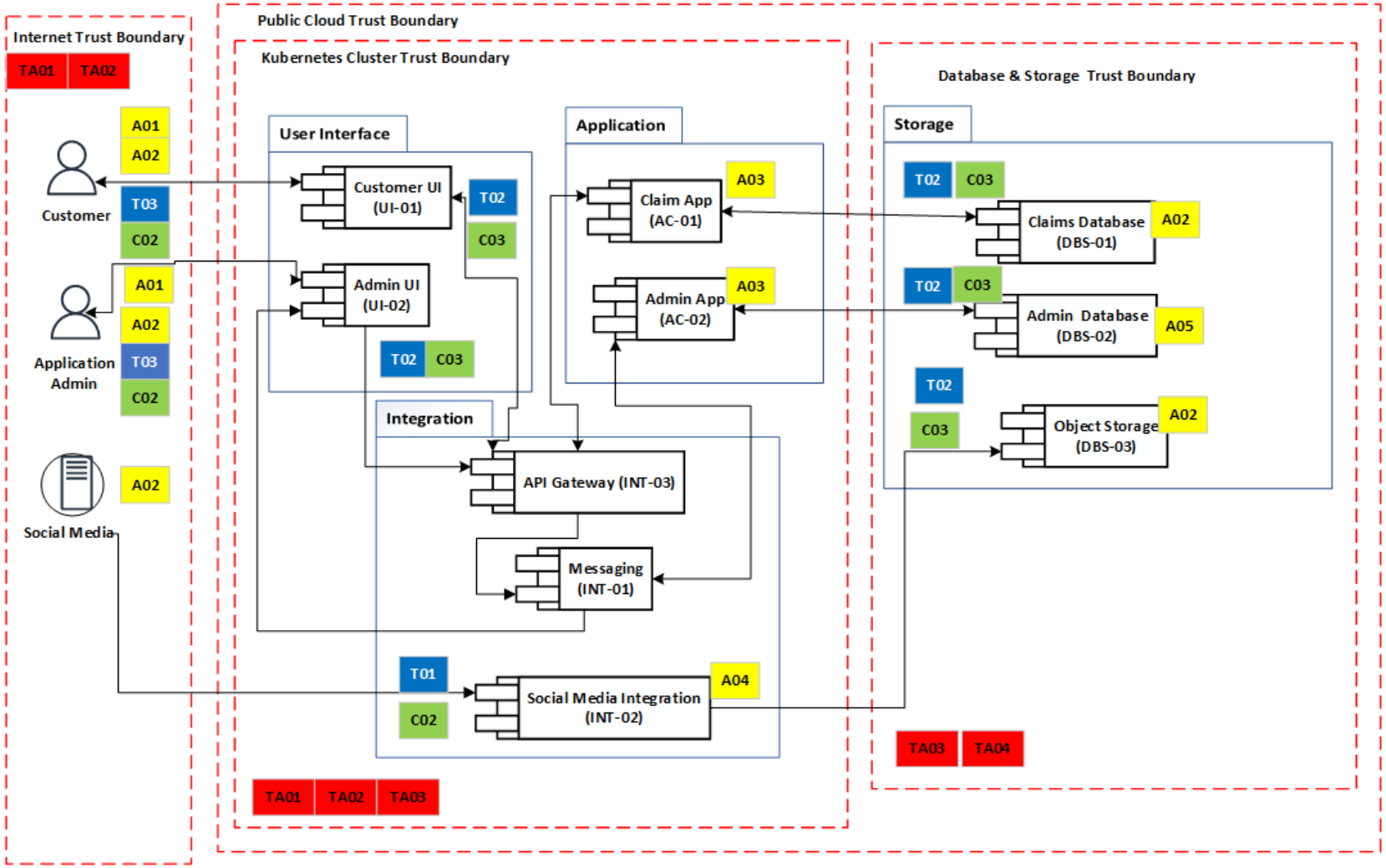
Application Security – Component Architecture – assets, threat actors, threats, controls (cont.)

- Identify Controls
  - There are three categories of security controls:
    - Detective - including, for example, Intrusion Detection Systems (IDS), Security Information and Event Management (SIEM), Log Monitoring and Analysis, Security Audits and Assessments, Continuous Compliance
    - Preventive – including, for example, Access Control Systems, Firewalls, Antivirus and anti-malware software, Security Awareness Training, Software Development Proactive Controls
    - Corrective – including, for example, Incident Response Plans, Backup and Disaster Recovery, Patch Management, Forensic Analysis
  - The following framework can be used for identification of relevant and effective controls:
    - MITRE ATT&CK framework
    - Common Attack Pattern Enumeration and Classification
    - The 18 CIS Critical Security Controls
  - The threat modelling process can either be based on a component architecture diagram or a data flow diagram. The next slide show how it can be used on the Component Architecture diagram
  - Update security controls if needed (previous slide (Slide 17) “Application Security – domains, categories, services”)

Application Security – Component Architecture – assets, threat actors, threats, controls (cont.)

- Threat Model checklist
  - Besides the functional assets in a system, we also need to identify meta data, logs, etc., which can also contain data fragments of our functional assets.
  - There are various methods available to identify threats, including OWASP Top 10, STRIDE, and others. Start with a high-level view and iterate through the different levels of detail over time, depending on the location of the critical assets.
  - Make sure that you have defined controls for all the threats you identified.
  - Identified controls should reduce the likelihood and/or impact of the associated risk in the intended direction. If a control has no impact on either likelihood or impact, it is basically useless.

Application Security – Component Architecture – assets, threat actors, threats, controls (cont.)



Assets

A01 – User Session ID
A02 – Customer Information
A03 – DB Access Credentials
A04 – Storage Credentials
A05 – App Configuration

Threat Actors

TA01 – External authorised
TA02 – External unauthorised
TA03 – Internal authorized
TA04 – Internal unauthorised

Threats

T01 – Lack of IAM Controls
T02 – Missing sec. transp. Layer
T03 – Exploit of website vulns

Controls

C01 – Multi Factor Authentication
C02 – Web Application Firewall
C03 - Encryption

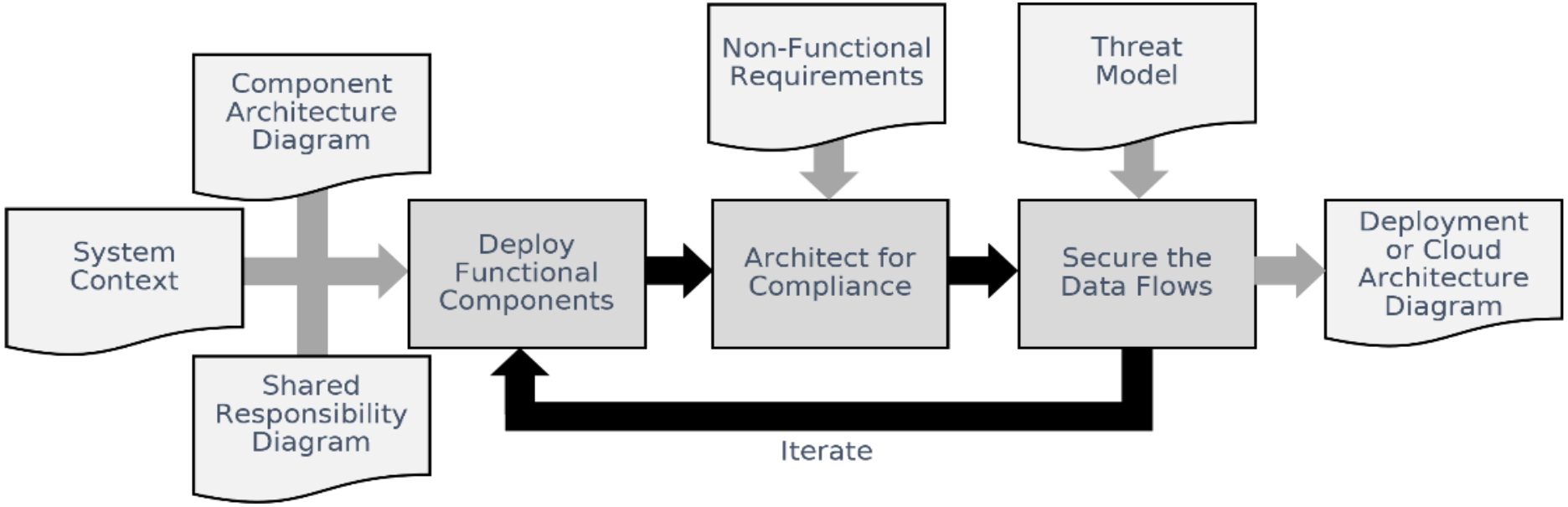
Infrastructure Security

- Requirements traceability is an important aspect of a solution. In the infrastructure architecture, the focus is on the non-functional requirements, including the security requirements related to
  - compliance,
  - general cyber risk mitigation, and
  - the mitigation actions resulting from the threat modeling.
- The format of the non-functional requirements traceability table could look like this:

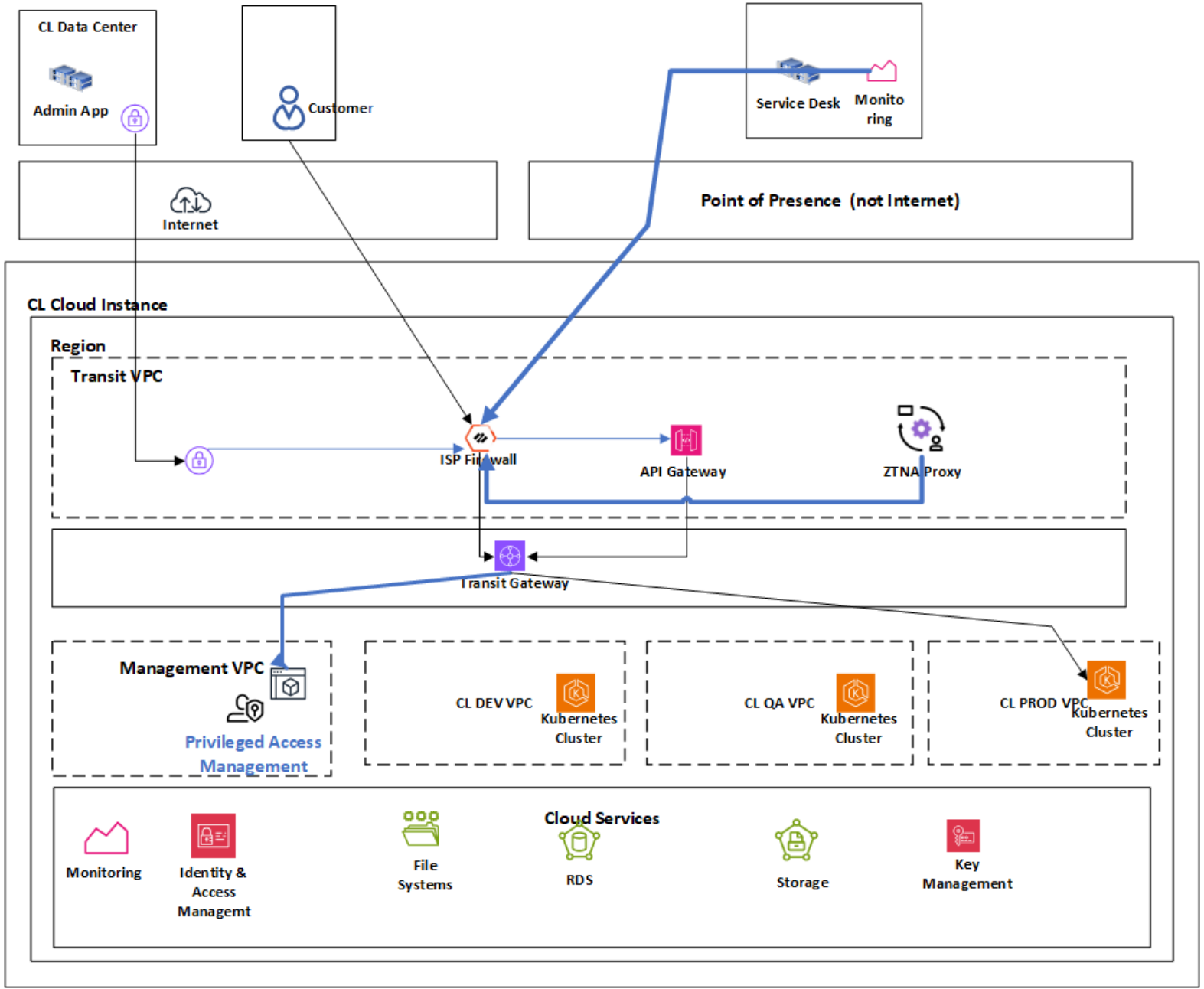
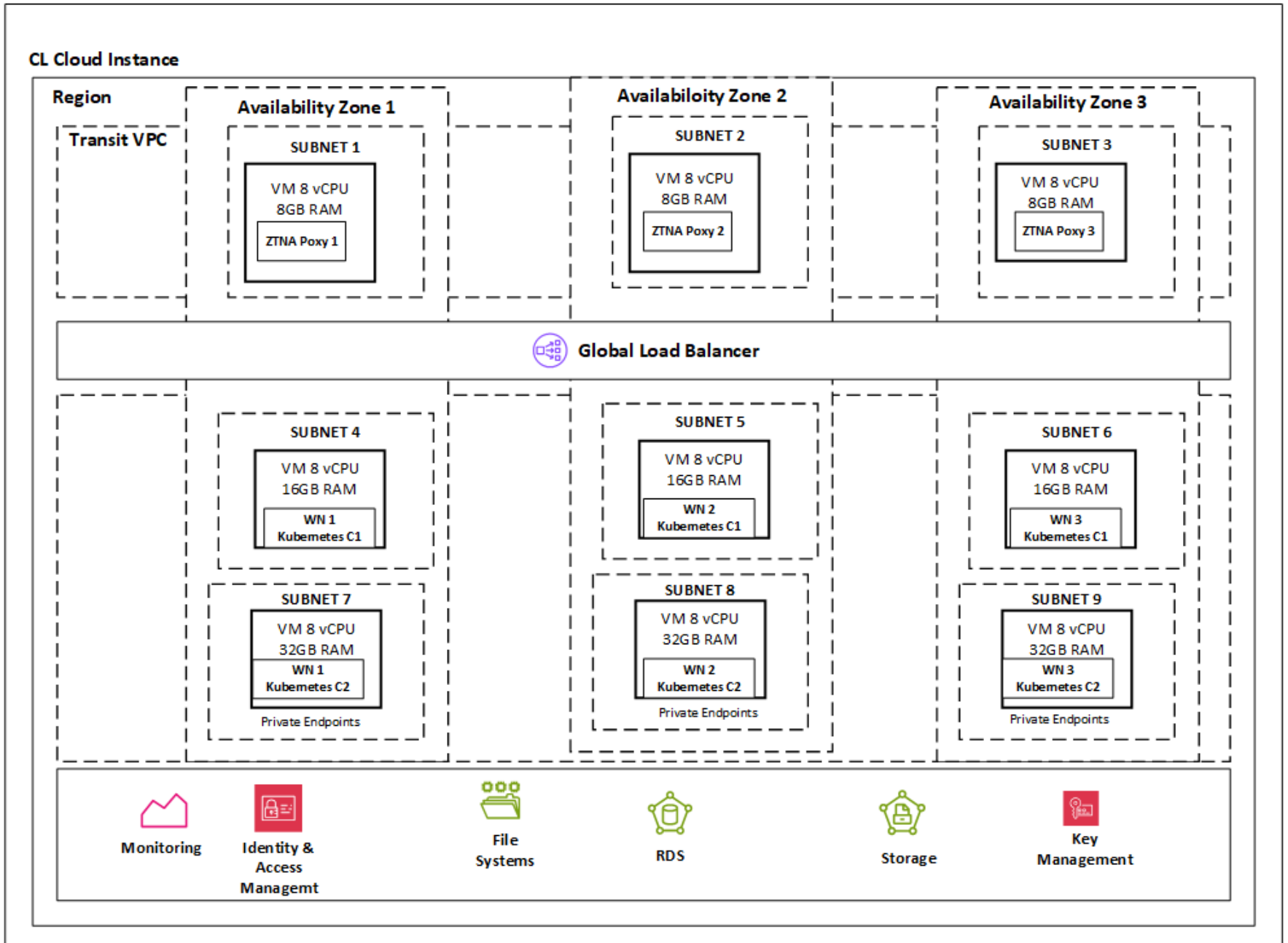
Req. ID	Requirement	High Level Design	Low Level Design	Test Plan	Documentation

Infrastructure Security Flow

- The Deployment Architecture diagram is a foundation for designing security for infrastructure. The overall architectural thinking process flow to include security into the deployment architecture looks like this:



Infrastructure Security - Deployment Architecture - Zero Trust Network Access (ZTNA)



Infrastructure Security – Cloud Architecture